# Zabezpečený přenos dat

**ISA - Laboratorní cvičení č.2**

Vysoké učení technické v Brně

`https://github.com/nesfit/ISA/tree/master/lab2-zabezpeceni`

## Cíl cvičení

- Seznámit se se synchronizací času a protokolem NTP (Network Time Protocol).
- Nakonfigurovat zabezpečený vzdálený přístup pomocí nástroje SSH (Secure Shell).
- Analyzovat komunikaci zabezpečenou protokolem TLS (Transport Layer Security).

## Obecné pokyny

- Vypněte si mobily a uschovejte do tašek. Není dovoleno používat mobily během výuky.
- Přihlaste se v OS Linux (F3) jako uživatel `user` s heslem `user4lab`.
- V případě potřeby se přepněte na uživatele `root` příkazem `su` (switch user), heslo `root4lab`.
- Pro editaci konfiguračních souborů můžete použít libovolný editor (nano, mcedit, vim, gedit).
- Při práci budete používat jméno počítače ve formátu hXX, kde XX je číslo vašeho počítače.

## 1 Synchronizace času pomocí protokolu NTP

Pro automatizovanou synchronizaci hodin na síťových zařízeních se využívá protokol NTP (Network Time Protocol), viz kapitolu 5 v laboratorním manuálu. Správná synchronizace času je nezbytná pro zajištění bezpečnosti zejména kvůli časovým razítkům omezujícím platnost klíčů, certifikátů či elektronických podpisů.

1. Příkazem `systemctl status chronyd.service` zjistěte, zda na počítači běží služba `chronyd` pro synchronizaci času pomocí protokolu NTP. Příkazem `chronyc sources` zkontrolujte seznam serverů, které váš počítač používá pro synchronizaci času. OK = `active (running)`.

2. Do protokolu vyplňte nakonfigurované NTP servery – u každého zapište doménové jméno nebo IP adresu. Dále u serverů vyplňte nastavení příznaků *M*, *S* a hodnotu *Stratum*. V protokolu vysvětlete význam těchto hodnot, viz `man chronyc`. `^` server; `*` vybraný, `+` použitý, `-` ne.

3. Jako uživatel `root` otevřete konfiguračního soubor `/etc/chrony.conf`. V souboru nahraďte implicitní NTP servery CentOS (`*.centos.pool.ntp.org`) za server na FIT (`ntp.fit.vutbr.cz`), viz `man chrony.conf`. Zakomentovat `#`, přidat `server ntp.fit.vutbr.cz iburst`.

4. Restartujte démona NTP příkazem `systemctl restart chronyd.service`. Bez výstupu OK.

5. Ověřte pomocí příkazu `systemctl status chronyd.service`, zda služba běží. Pokud neběží, zjistěte chybu příkazem `journalctl -u chronyd`. Případnou chybu opravte v konfiguraci a službu `chronyd` znovu restartujte. Typická chyba: překlep v názvu serveru nebo chybí slovo `server`.

6. Pomocí příkazu `chronyc sources` ověřte, zda je čas správně synchronizován se serverem NTP na FIT. Má být `^* ntp.fit.vutbr.cz`; jinak chvíli počkat (`chronyc tracking`).

## 2 Zabezpečený vzdálený přístup pomocí SSH (práce ve dvojicích)

Nástroj SSH (Secure Shell) se používá pro bezpečné připojení na vzdálený počítač. Více podrobností ke službě SSH najdete v kapitole 6 laboratorního manuálu.

1. Otevřete si **dvě terminálová okna**: jedno pro uživatele `user`, v druhém se příkazem `su - root` přepněte na uživatele `root`. Pro roota `su -`, heslo `root4lab`.

2. Pomocí příkazu `whoami` ověřte v obou terminálech jméno aktivního uživatele.
   (V jednom terminálu bude `user`, v druhém `root`.) Prompt `$` = user, `#` = root.

3. V obou terminálových oknech dočasně vypněte podporu pro SSH agenta příkazem `unset`:

   ```
   [user@hXX]$ unset SSH_AUTH_SOCK
   [root@hXX]# unset SSH_AUTH_SOCK
   ```

   Pokud budete otevírat v průběhu řešení nové terminály, nezapomeňte v nich tímto způsobem vypnout podporu agenta SSH. Kontrola: `echo $SSH_AUTH_SOCK` je prázdné.

4. Bezpečné připojení na vzdálený počítač bez autentizačních klíčů:

   (a) Běžte do terminálu uživatele `root`. Spusťte program Wireshark a zachytávejte komunikaci na portu 22 (rozhraní enp2s0). Spustit `wireshark &`, capture filtr `tcp port 22`.

   (b) Běžte do terminálu uživatele `user`. Přihlaste se pomocí `ssh` na počítač svého souseda hYY (např. h01): příkaz `ssh user@hYY.netlab.fit.vutbr.cz`. Zadejte heslo uživatele `user`.

   (c) Na vzdáleném počítači zadejte libovolný příkaz, např. výpis manuálové stránky ssh (`man ssh`), obsahu adresáře (`ls`) či login aktuálního uživatele (`whoami`). Na dotaz `yes`.

   (d) Příkazem `exit` nebo stiskem `Ctrl-D` ukončete spojení SSH. Heslo `user4lab`.

   (e) V programu Wireshark nastavte display filter na `ssh`. Zjistěte, jaký algoritmus byl použit pro výměnu klíčů. Odpověď zapište do protokolu. Výsledek: `curve25519-sha256`.

   (f) V programu Wireshark zobrazte obsah komunikace SSH pomocí `Follow TCP stream`. Podívejte se, co lze ze zobrazené komunikace vyčíst. Výsledek zapište do protokolu. Poté můžete program Wireshark ukončit. Čitelný jen banner `SSH-2.0-OpenSSH` a seznam algoritmů.

5. Vytvoření veřejného a privátního klíče pro službu SSH:

   *Pozn.:* Klíče budete vytvářet na **svém počítači**. Podle promptu `uzivatel@hXX` si vždy ověřte, zda jste přihlášen jako uživatel `user` nebo `root` a zda `XX` odpovídá číslu vašeho počítače!

   (a) Jako uživatel `user` vygenerujte příkazem `$ ssh-keygen -C <login>@user`[1] implicitní klíč pro uživatele `user`. Ponechte implicitní názvy souborů pro uložení klíčů. Zvolte heslo o délce alespoň osmi znaků, například `fitvutisa`. Heslo se používá pro přístup k soukromému klíči.

   (b) Jako uživatel `root` vygenerujte příkazem `# ssh-keygen -N "" -C <login>@root` implicitní klíč pro uživatele `root` bez hesla. U (a) heslo 2×, cestu potvrdit Enter.

[1] Řetězec `<login>` nahraďte svým loginem, např. xstudent00.

(c) Pod oběma uživateli ověřte obsah a přístupová práva nově vzniklých souborů (`ls -l ~/.ssh`).

(d) Do protokolu uveďte, jaký je význam obou klíčů, v jakých souborech jsou uloženy a jak je nastaven přístup k těmto souborům (unixová přístupová práva), více viz `man ssh`.

6. Distribuce klíčů: Nejdřív pod user (heslo `user4lab`), pak pod root (heslo `root4lab`).

   (a) Oba veřejné klíče zkopírujte na vzdálený počítač hYY do souboru `.ssh/authorized_keys`. Můžete využít následující postup:

   - Klíč uživatele `user` zkopírujte příkazem `ssh-copy-id` (viz `man ssh-copy-id`):
     `ssh-copy-id -i ~user/.ssh/id_rsa.pub user@hYY`
   - Na vzdáleném počítači nastavte správně přístupová práva k souboru:
     `ssh user@hYY "chmod 600 ~/.ssh/authorized_keys"`
   - Pod uživatelem `root` zkopírujte na vzdálený počítač také veřejný klíč uživatele `root`:
     `ssh-copy-id -i /root/.ssh/id_rsa.pub root@hYY`
   - Zkontrolujte obsah obou souborů a ověřte, zda jsou klíče přidány:
     `ssh user@hYY "cat ~user/.ssh/authorized_keys"`
     `ssh root@hYY "cat /root/.ssh/authorized_keys"`

   (b) Pod uživatelem `user` se zkuste znovu přihlásit jako `user` na vzdálený počítač: `ssh user@hYY`. Pod uživatelem `root` se znovu přihlaste jako `root`, tedy: `ssh root@hYY`. Vzdálená sezení opět ukončete příkazem `exit` nebo stiskem `Ctrl-D`. User chce heslo ke klíči, root nic.

   (c) Do protokolu uveďte, jaká hesla bylo nutné zadat při přihlášení. Vysvětlete význam souboru `authorized_keys`. Soubor = seznam veřejných klíčů, které se smí přihlásit.

   (d) Pod uživatelem `user` se zkuste znovu přihlásit jako `user` na počítač hYY. Zkuste několikrát opakovaně zadat špatné heslo pro přístup ke klíči. Změnilo se něco? Do protokolu napište, jaké heslo po vás požadoval program SSH k připojení na vzdálený počítač po chybném zadání hesla ke klíči. Při experimentu použijte režim verbose (`ssh -v`). Pak heslo účtu.

7. Použití služby SSH pro vzdálené spuštění příkazu:

   Nyní omezíme použití klíče uživatele `root` pouze na spuštění konkrétního příkazu na vzdáleném počítači. Následující příkazy zadávejte v okně uživatele `root`:

   (a) Přihlaste se jako uživatel `root` na počítač hYY, kam jste nakopírovali své veřejné klíče.

   (b) Na vzdáleném počítači upravte soubor s autorizovanými veřejnými klíči tak, že na začátek řádku s klíčem uživatele `root`[2] přidáte příkaz `command="chronyc -n sources"` následovaný mezerou a původním obsahem řádku. Tento příkaz se spustí místo vzdáleného přihlášení.

   (c) Odhlaste se ze vzdáleného počítače. Editace: `vi ~/.ssh/authorized_keys`.

   (d) Znovu se přihlaste jako `root` na sousední počítač hYY pomocí SSH z účtu `root`. Co se zobrazilo na výstupu terminálu? Vysvětlení zapište do protokolu. Výpis NTP zdrojů.

8. Opakované použití klíče zabezpečeného heslem pomocí agenta SSH:

   (a) Otevřete si **nový unixový terminál** pod uživatelem `user`. Pomocí příkazu `env` ověřte, jak je nastavená proměnná `SSH_AUTH_SOCK` (Pozn. proměnná musí být nastavena.).

   (b) Přihlaste se znovu k sousednímu počítači hYY. `env | grep SSH`; bez `unset`!

   (c) Odhlaste se a znovu přihlašte na sousední počítač. Jak proběhlo přihlášení? Výsledek zapište do protokolu. Heslo ke klíči jen poprvé (agent jej uloží), pak už bez hesla.

[2] Řádek poznáte tak, že končí řetězcem `<login>@root`.

# 3 Zabezpečení transportní vrstvy pomocí TLS

V této části budeme analyzovat zabezpečený přenos pomocí TLS (Transport Layer Security). Více podrobností k TLS najdete v laboratorním manuálu, kapitole 7.

1. Nezabezpečený přenos dat.
   (a) Spusťte program Wireshark a zachytávejte komunikaci na portu 80. Filtr `tcp port 80`.
   (b) Pomocí programu `telnet` se připojte k fakultnímu webovému serveru: `telnet nes.fit.vutbr.cz 80`. Když telnet chybí: `nc nes.fit.vutbr.cz 80`
   (c) V programu Wireshark pozorujte navázání spojení pomocí trojcestné synchronizace TCP.
   (d) Zašlete serveru požadavek protokolem HTTP, např. `GET / HTTP/1.0`. Dotaz ukončete prázdným řádkem – tj. je nutné 2x stisknout ENTER. V terminálu pozorujte odpověď. Psát rychle.
   (e) Zobrazte komunikace HTTP v programu Wireshark. Do protokolu uveďte, zda je možné vidět obsah odchycené komunikace. Follow TCP Stream: GET i HTML čitelné.
2. Přenos dat zabezpečený protokolem TLS.
   (a) Spusťte program Wireshark a odchytávejte komunikaci na portu 443. Filtr `port 443`.
   (b) Pomocí programu `openssl` se připojte k fakultnímu webovému serveru: `openssl s_client -connect www.fit.vutbr.cz:443 -tls1_2`. Všimněte si řádku *Verify return code*. Co říká o certifikátu? `0 (ok)` = certifikát ověřen.
   (c) V programu Wireshark pozorujte navázání spojení TCP a TLS. Zaměřte se na pakety `Client Hello` a `Server Hello`. Jak je možné z odchycené komunikace zjistit jméno serveru? Zapište odpověď do protokolu. Client Hello, rozšíření `server_name` (SNI).
   (d) Pomocí příkazu z bodu (b) se opět připojte k serveru. Zašlete (do konzole zadejte) požadavek protokolem HTTP, např. `GET / HTTP/1.0`. Dotaz ukončete prázdným řádkem (opět 2x ENTER). V terminálu pozorujte odpověď. Psát rychle, jinak timeout.
   (e) Zobrazte tuto odchycenou komunikaci ve Wiresharku. Do protokolu uveďte, zda je možné přečíst obsah komunikace. Jen Application Data, obsah šifrován.
   (f) Z výstupu aplikace `openssl` určete, jaká šifrovací sada (cipher suite) se používá. Identifikátor šifrovací sady zapište do protokolu. Hledat řádek `Cipher :` v SSL-Session.
   (g) Na stránce `https://ciphersuite.info/` vyhledejte detaily k dané šifrovací sadě. Do protokolu vyplňte názvy použitých algoritmů pro zabezpečení komunikace TLS.
3. **Zabezpečený přenos dat TLS ve webovém prohlížeči**
   (a) V prohlížeči Firefox otevřete stránku `wis.fit.vutbr.cz`. Přihlášení není nutné.
   (b) Klikněte na ikonku zámku nalevo od URL a zjistěte, jaká šifrovací sada je použita pro dané zabezpečené připojení k serveru. Zobrazte informace o použitém certifikátu. Požadované údaje vyplňte do protokolu. Zámek, More information, View Certificate.
   (c) V menu *Edit* ≫ *Settings* ≫ *Privacy & Security* v sekci *Certificates* zobrazte certifikáty autorit, kterým důvěřujete (záložka *Authorities*). Do protokolu vypište názvy alespoň tří z nich. Rychle: `about:preferences#privacy`, tlačítko View Certificates.

# 4 Ukončení práce v laboratoři

- Odevzdejte podepsaný a vyplněný protokol vyučujícímu.
- Jako uživatel `root` spusťte dávku `/root/isa2/clean`, která odstraní vaši konfiguraci a vypne počítač. Nejdřív odevzdat protokol, pak `/root/isa2/clean` jako root.